PROJECT TITLE : DESIGN AND APPLY CONTEXT-AWARE ACCESS CONTROLS BASED ON USER IDENTITY, DEVICE POSTURE, LOCATION, AND APPLICATION RISK.

COLLEGE NAME : Nandha Arts And Science College

COLLEGE CODE : BRU4J

GROUP CODE : SWTID-2026-2848

CONTACT : 7810098263

TEAM DETAILS

Team Leader: DEVA SURYA B

Email : surya280066@gmail.com

Team member : ADHICHANDIRA S

Email : adhichandirasekar@gmail.com

Team member : SHAKTHIMURUGAN N

Email : shakthimurugan965@gmail.com

Team member : KIRUBASHANKAR S

Email : Kirubashankars005@gmail.com

Team member : NANDHA KUMAR S S

Email : nk9200995@gmail.com

INTRODUCTION

In today's digital landscape, organizations face increasing challenges in safeguarding sensitive data and applications against evolving cyber threats. Traditional access control models, which rely solely on static credentials such as usernames and passwords, are no longer sufficient to ensure secure and seamless user experiences. To address these challenges, context-aware access controls have emerged as a dynamic and intelligent approach to security.

Context-aware access control systems evaluate multiple factors in real time—such as user identity, device posture, location, and application risk—before granting or restricting access. This adaptive model ensures that access decisions are not only based on who the user is, but also on the trustworthiness of the device they are using, the geographical location from which they are connecting, and the sensitivity or risk level of the application being accessed. For example, a verified employee logging in from a corporate device at headquarters may be granted full access, while the same employee attempting to connect from an unknown device in a high-risk region may be required to undergo additional authentication or be denied access altogether.

By integrating identity management with endpoint security, geolocation analysis, and application risk assessment, organizations can create a zero-trust environment where access is continuously verified rather than assumed. This approach not only strengthens defenses against unauthorized access and insider threats but also enhances compliance with regulatory requirements and improves user productivity by tailoring access to specific contexts.

Ultimately, designing and applying context-aware access controls represents a critical step toward modernizing enterprise security. It enables organizations to balance security and usability, ensuring that legitimate users can work efficiently while malicious actors are effectively blocked. As cyber threats grow more sophisticated, context-aware access control stands as a cornerstone of resilient, adaptive, and future-ready security architectures.

ABSTRACT

The rapid evolution of digital ecosystems and the increasing sophistication of cyber threats have rendered traditional static access control mechanisms inadequate. Modern enterprises require adaptive, intelligent security frameworks that can dynamically evaluate risk and enforce policies in real time. Context-aware access controls represent a transformative approach to identity and access management, integrating multiple contextual factors—user identity, device posture, location, and application risk—to deliver secure, flexible, and user-centric access decisions.

This paradigm shifts security from a one-size-fits-all model to a risk-based adaptive model, where access privileges are continuously assessed and adjusted according to the trustworthiness of the user and their environment. For instance, a verified employee accessing a low-risk application from a compliant corporate device may be granted seamless access, while the same employee attempting to access a high-risk application from an untrusted device in a suspicious location may face additional authentication or restrictions. Such granularity ensures that legitimate users maintain productivity while malicious actors are effectively deterred.

The integration of identity verification, endpoint security monitoring, geolocation analysis, and application risk profiling enables organizations to establish a zero-trust architecture, where trust is never assumed but constantly validated. This approach not only strengthens defenses against insider threats and external attacks but also supports compliance with regulatory standards and enhances operational resilience.

Ultimately, designing and applying context-aware access controls is essential for organizations seeking to balance security, usability, and compliance in an increasingly complex digital environment. By leveraging contextual intelligence, enterprises can achieve a future-ready security posture that adapts to evolving risks while empowering users with secure and efficient access to resources.

USE CASE SENARIO :

1 Remote Employee Access to Corporate Applications

A company employee attempts to log in to the corporate CRM system from a personal laptop at home.

- **Identity:** Verified through single sign-on (SSO).
- **Device Posture:** The laptop fails endpoint compliance checks (no antivirus, outdated OS).
- **Location:** Remote, outside corporate network.
- **Application Risk:** CRM contains sensitive customer data.
  Access Decision: The system requires multi-factor authentication (MFA) and restricts access to read-only mode until the device posture is remediated.

2 Contractor Access to Development Environment

A contractor is hired to work on a project and needs access to the development server.

- **Identity:** Verified contractor account with limited privileges.
- **Device Posture:** Device passes compliance checks (encrypted disk, updated patches).
- **Location:** Connecting from a trusted office network.
- **Application Risk:** Development server has moderate risk.
  Access Decision: Granted full access but only during business hours, with monitoring enabled to detect unusual activity.

3 Suspicious Login Attempt from Abroad

An employee account is used to attempt login from a country where the company has no operations.

- **Identity:** Valid credentials entered.
- **Device Posture:** Unknown, unregistered device.
- **Location:** High-risk region flagged by geolocation analysis.

- **Application Risk:** Attempted access to financial reporting system.
  Access Decision: Access is blocked, and the security team is alerted to investigate possible credential theft.

4 Mobile Device Access to Cloud Storage

An employee tries to access cloud storage from a smartphone while traveling.

- **Identity:** Verified corporate account.
- **Device Posture:** Device is compliant but connected via public Wi-Fi.
- **Location:** Airport lounge, flagged as untrusted network.
- **Application Risk:** Cloud storage contains sensitive intellectual property.
  Access Decision: User is required to connect through a corporate VPN before access is granted.

5 Executive Access to High-Risk Application

A senior executive attempts to access the company's financial dashboard.

- **Identity:** Verified executive account with high privileges.
- **Device Posture:** Corporate-issued laptop, fully compliant.
- **Location:** Corporate headquarters.
- **Application Risk:** Financial dashboard is classified as high-risk.
  Access Decision: Full access granted, but session is continuously monitored with anomaly detection to prevent insider threats.

Stage 1

TITLE : Design And apply context-aware access controls based on user identity, device posture, location, and application risk.

OVERVIEW :

Overview: Context-Aware Access Controls

Modern organizations face increasing challenges in securing digital assets against evolving cyber threats, insider risks, and compliance requirements. Traditional access control models, which rely on static credentials or role-based permissions, are no longer sufficient in dynamic environments where users connect from diverse devices, locations, and networks. To address these challenges, **context-aware access controls** have emerged as a critical component of adaptive security strategies.

Context-aware access control systems evaluate multiple factors in real time before granting or restricting access. These factors include **user identity** (who is requesting access), **device posture** (the security health of the device being used), **location** (geographical or network origin of the request), and **application risk** (the sensitivity or criticality of the resource being accessed). By combining these elements, organizations can enforce policies that adapt to the risk level of each access attempt, rather than relying on static rules.

For example, a verified employee accessing a low-risk application from a compliant corporate device in the office may be granted seamless access. However, the same employee attempting to access a high-risk financial system from an untrusted device in a foreign location may be required to undergo multi-factor authentication or be denied access altogether. This dynamic approach ensures that legitimate users can remain productive while malicious actors are effectively blocked.

The business benefits of context-aware access controls are substantial. They strengthen defenses against unauthorized access, reduce the likelihood of data breaches, and support compliance with regulatory frameworks. At the same time, they improve user experience by tailoring access to specific contexts, avoiding unnecessary friction for low-risk scenarios.

In essence, designing and applying context-aware access controls represents a shift toward **zero-trust security**, where trust is never assumed but continuously verified. This approach balances **security, usability, and compliance**, enabling organizations to build resilient systems that adapt to evolving risks while empowering users with secure and efficient access to resources.

LIST OF VULNERABILITY

SNO	VULNERABILITY NAME	CWE/CVE no.
1	Absolute Path Traversal	CWE 36
2	Sensitive Cookie in HTTPS Session Without 'Secure' Attribute	CWE 614
3	Use of Unmaintained Third Party Components	CWE 1104
4	Use of Hard-coded Cryptographic Key	CWE 321
5	Improper Control of Generation of Code ('Code Injection')	CWE 94
6	Improper Privilege Management	CWE 269
7	Improper Certificate Validation	CWE 295
8	Uncontrolled Search Path Element	CWE 427
9	Improper Output Neutralization for Logs	CWE 117
10	Uncaught Exception	CWE 248

Report :

Vulnerability Name : Absolute Path Traversal

CWE/CVE no : CWE 36

Owasp category : A01:2025 Broken Access Control

Description :

Absolute Path Traversal is a vulnerability where attackers use full system file paths (e.g., /etc/passwd or C:\Windows\system32\config) to access sensitive files outside an application's intended directories due to poor input validation. Proper input validation, path normalization, least-privilege permissions, and secure file-handling practices are essential to prevent unauthorized access and protect system data.

Bussiness impact :

Absolute Path Traversal is not just a technical vulnerability—it carries significant **business consequences** that can affect an organization's financial stability, reputation, and compliance posture. When attackers exploit this flaw, they gain unauthorized access to sensitive files and system resources, which can directly translate into operational and strategic risks for the business.

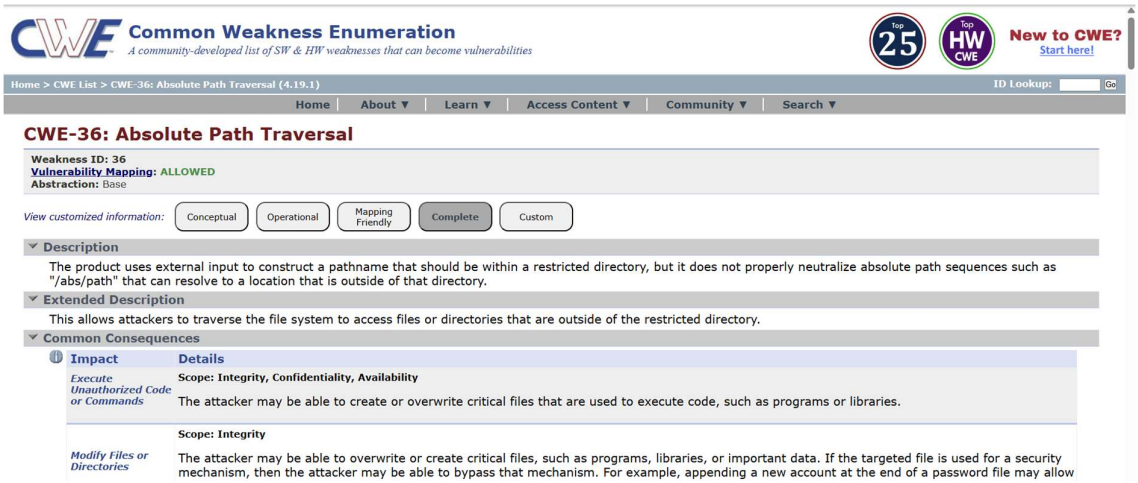
From a **financial perspective**, the exposure of confidential data such as customer records, intellectual property, or system credentials can lead to costly breaches. Organizations may face expenses related to incident response, system recovery, and potential fines from regulatory bodies. In industries governed by strict compliance standards (such as healthcare, finance, or e-commerce), failure to protect sensitive information can result in penalties under frameworks like GDPR, HIPAA, or PCI DSS.

The **reputational impact** is equally severe. Customers and partners expect organizations to safeguard their data, and a breach caused by path traversal can erode trust. Loss of confidence may lead to customer churn, reduced market share, and long-term damage to brand credibility. In competitive industries, even a single incident can give rivals an advantage by undermining stakeholder confidence in the affected company's security practices.

Operationally, exploitation of absolute path traversal can disrupt business continuity. Attackers may alter or delete critical files, inject malicious code, or escalate privileges to gain control over systems. Such disruptions can halt services, delay projects, and reduce employee productivity. For businesses that rely heavily on digital platforms, downtime translates directly into lost revenue opportunities.

Finally, the **strategic impact** lies in the organization's ability to innovate and grow. Companies burdened by recurring security incidents may divert resources away from innovation to focus on remediation. This reactive posture can slow digital transformation initiatives and weaken competitiveness in the market.

In summary, Absolute Path Traversal is more than a technical flaw—it is a business risk with wide-ranging consequences.



Vulnerability Name : Sensitive Cookie in HTTPS Session Without 'Secure' Attribute

CWE/CVE no : CWE 614

Owasp category : A02:2025 Security Misconfiguration

Description :

Sensitive cookies in an HTTPS session without the Secure attribute can be transmitted over insecure HTTP, exposing them to interception through attacks like man-in-the-middle (MITM) and session hijacking. Setting the Secure and HttpOnly attributes, enforcing HTTPS, and using HSTS helps protect session data and prevent unauthorized access.

Bussiness impact :

Failing to set the **Secure attribute** on sensitive cookies in HTTPS sessions can have serious business consequences that extend beyond technical vulnerabilities. Cookies often store critical information such as session identifiers, authentication tokens, or user preferences. If these cookies are transmitted without the Secure flag, they risk being exposed through insecure HTTP connections, leaving organizations vulnerable to interception, theft, and misuse.

From a **financial standpoint**, the compromise of session cookies can lead to unauthorized access to customer accounts, financial data, or proprietary systems. This may result in direct monetary losses, fraud, or costly remediation efforts. Additionally, organizations may face fines and penalties for failing to comply with data protection regulations such as GDPR, HIPAA, or PCI DSS, where secure handling of user data is a legal requirement.

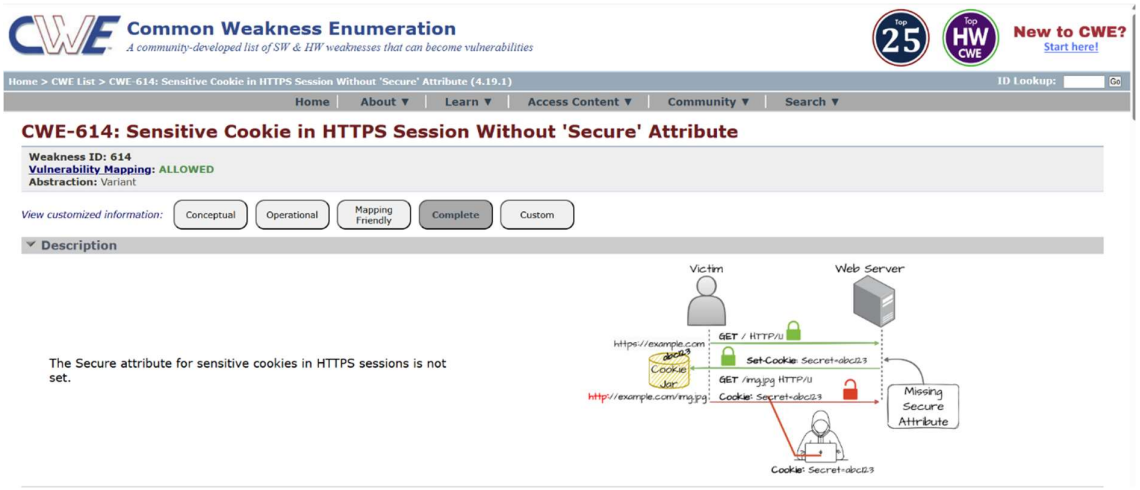
The **reputational impact** is equally significant. Customers expect their data to be protected, and a breach caused by insecure cookies can erode trust and confidence. Loss of customer trust often translates into reduced loyalty, negative publicity, and long-term damage to brand credibility. In competitive industries, even a single incident can weaken market position and give rivals an advantage.

Operationally, insecure cookies can disrupt **business continuity**. Attackers who hijack sessions may gain administrative access, alter system configurations, or disrupt services. This can lead to downtime, reduced employee productivity, and interruptions in customer-facing platforms. For businesses that rely heavily on digital services, such disruptions directly affect revenue and customer satisfaction.

Strategically, repeated security incidents caused by poor cookie management can force organizations to divert resources from innovation and growth to damage control and compliance efforts. This reactive posture slows digital transformation initiatives and undermines competitiveness in the marketplace.

In summary, the absence of the Secure attribute on sensitive cookies is not a minor oversight—it is a **business risk** with wide-ranging consequences. By enforcing secure cookie

practices, organizations can protect sensitive data, maintain compliance, preserve customer trust, and safeguard their long-term financial and strategic goals.



Vulnerability Name : Use of Unmaintained Third Party Components

CWE/CVE no : CWE 1104

Owasp category : A03:2025 Software Supply Chain Failures

Description :

Using unmaintained third-party components in applications can expose systems to unpatched vulnerabilities, compatibility issues, and security risks because they no longer receive updates or fixes. Regular dependency audits, replacing outdated libraries, and using tools like SBOM help organizations maintain secure and reliable software.

Bussiness impact :

The reliance on **unmaintained third-party components** poses significant business risks that extend far beyond technical vulnerabilities. These components, often integrated to accelerate development and reduce costs, can become liabilities when they are no longer supported or updated by their creators.

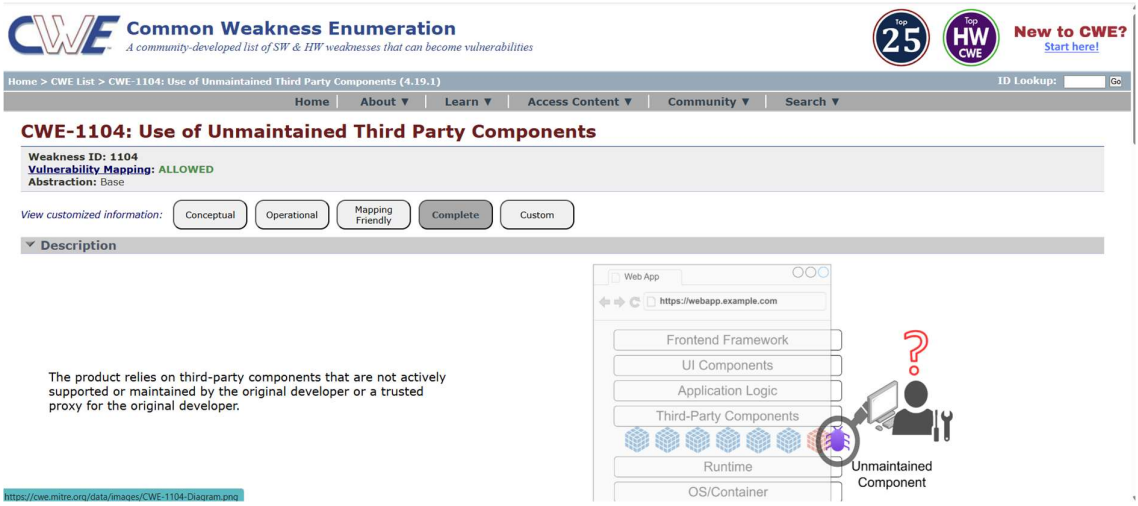
From a **financial perspective**, unmaintained components expose organizations to unpatched security flaws that attackers can exploit. A successful breach can lead to direct monetary losses, costly incident response, and potential fines for non-compliance with data protection regulations such as GDPR, HIPAA, or PCI DSS. Additionally, the hidden costs of downtime, lost productivity, and emergency patching can strain budgets and divert resources away from innovation.

The **reputational impact** is equally severe. Customers and partners expect organizations to maintain secure and reliable systems. If a breach or service disruption occurs due to outdated components, trust in the brand may erode. Negative publicity and customer churn can follow, damaging long-term relationships and weakening competitive advantage in the marketplace.

Operationally, unmaintained components can cause **system instability and compatibility issues**. As technology ecosystems evolve, unsupported libraries may fail to integrate with newer platforms, leading to crashes, degraded performance, or service outages. These disruptions directly affect business continuity, reducing employee efficiency and customer satisfaction.

Strategically, organizations that rely heavily on outdated components risk slowing down their **digital transformation initiatives**. Instead of focusing on innovation and growth, they may be forced into a reactive posture, constantly addressing vulnerabilities and compatibility problems. This diversion of resources can hinder competitiveness and delay the adoption of modern technologies.

In conclusion, the use of unmaintained third-party components is not simply a technical oversight—it is a **business risk** with wide-ranging consequences.



Vulnerability Name : Use of Hard-coded Cryptographic Key

CWE/CVE no : CWE 321

Owasp category : A04:2025 Cryptographic Failures

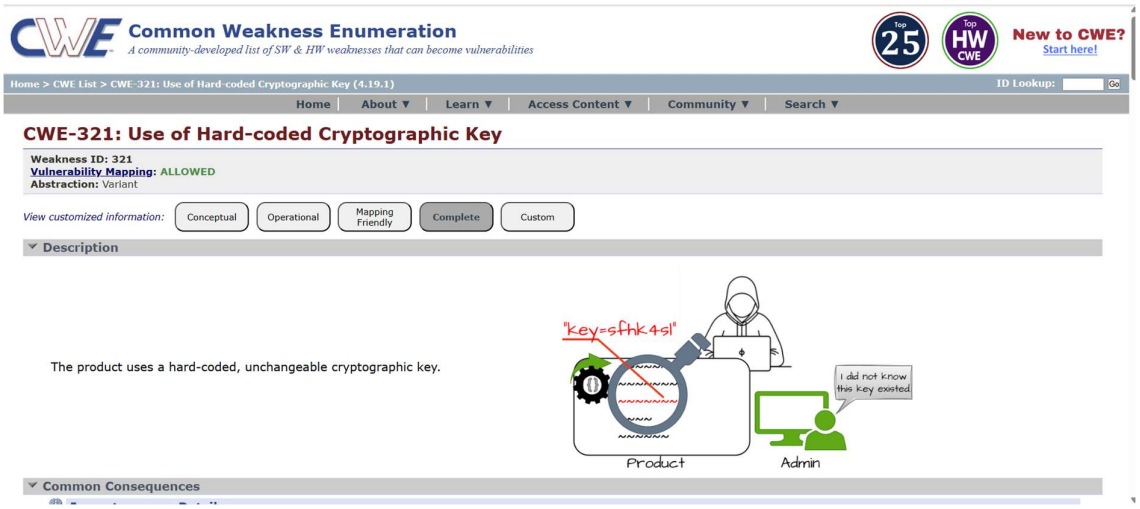
Description :

The **use of hard-coded cryptographic keys** occurs when encryption keys are directly embedded in the application's source code, making them accessible to attackers who can reverse-engineer or view the code. This can lead to **data breaches, unauthorized**

decryption, and compromised security, so keys should be stored securely using key management systems or environment variables instead of hard-coding

Bussiness impact :

The use of hard-coded cryptographic keys can lead to serious business impacts if attackers discover the embedded keys and gain unauthorized access to encrypted data. This may result in data breaches, financial loss, regulatory penalties, reputational damage, and loss of customer trust, affecting the organization's overall security and business continuity.



Vulnerability Name : Improper Control of Generation of Code ('Code Injection')

CWE/CVE no : CWE 94

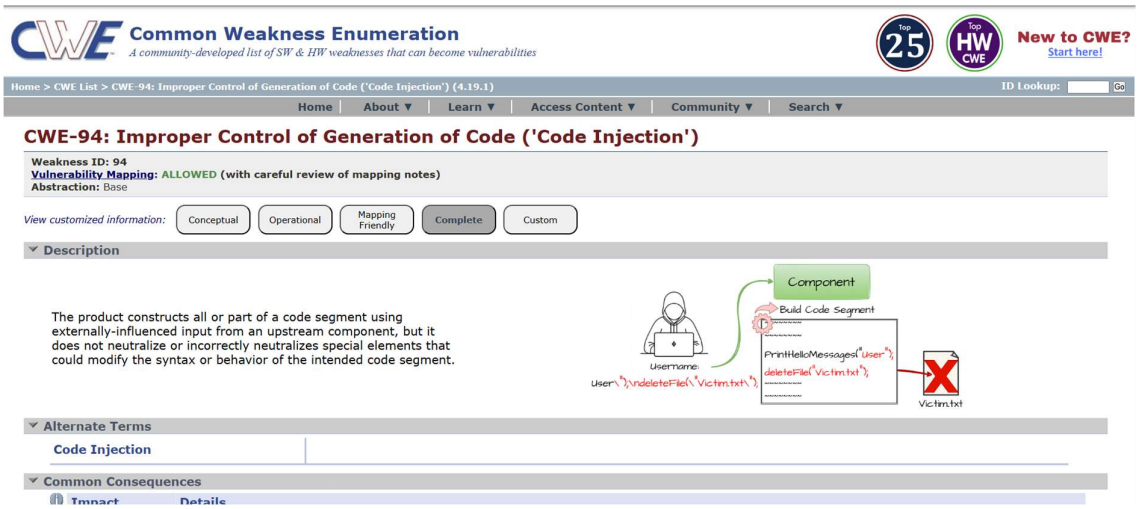
Owasp category : A05:2025 Injection

Description :

Improper Control of Generation of Code (Code Injection) is a security vulnerability that occurs when an application fails to properly validate or sanitize user input before using it to generate or execute code. This allows attackers to inject malicious code into the application, potentially leading to unauthorized access, data manipulation, system compromise, or complete takeover of the affected system

Bussiness impact :

The business impact of Improper Control of Generation of Code (Code Injection) includes unauthorized system access, data theft, and manipulation of critical business information. It can also cause financial losses, service disruption, legal penalties, and damage to the organization's reputation and customer trust



Vulnerability Name : Improper Privilege Management

CWE/CVE no : CWE 269

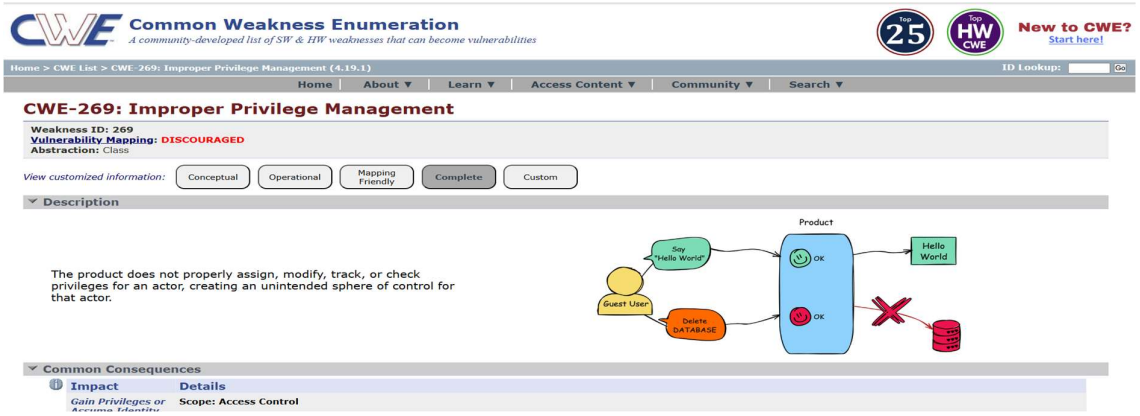
Owasp category : A06:2025 Insecure Design

Description :

Improper Privilege Management is a security vulnerability that occurs when an application fails to correctly assign, enforce, or restrict user permissions. This can allow users or attackers to gain unauthorized access to sensitive functions or data, potentially leading to system misuse, data exposure, or privilege escalation

Bussiness impact :

The business impact of Improper Privilege Management includes unauthorized access to sensitive data, system misuse, and potential data breaches. This can result in financial losses, regulatory penalties, operational disruption, and damage to the organization's reputation and customer trust



Vulnerability Name : Improper Certificate Validation

CWE/CVE no : CWE 295

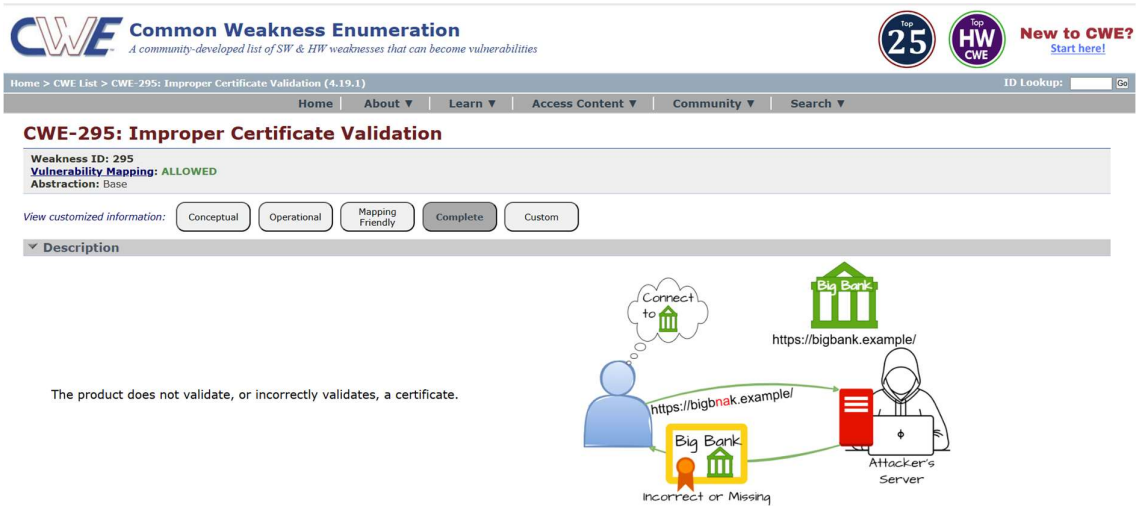
Owasp category : A07:2025 Authentication Failures

Description :

Improper Certificate Validation occurs when an application fails to properly verify the authenticity of SSL/TLS certificates during secure communications. This can allow attackers to intercept or manipulate encrypted data through man-in-the-middle (MITM) attacks, compromising the confidentiality and integrity of transmitted information

Bussiness impact :

This vulnerability can lead to data breaches, exposure of sensitive information, financial losses, and unauthorized access to systems. It may also cause regulatory penalties, reputational damage, and loss of customer trust for the organization.



Vulnerability Name : Uncontrolled Search Path Element

CWE/CVE no : CWE 427

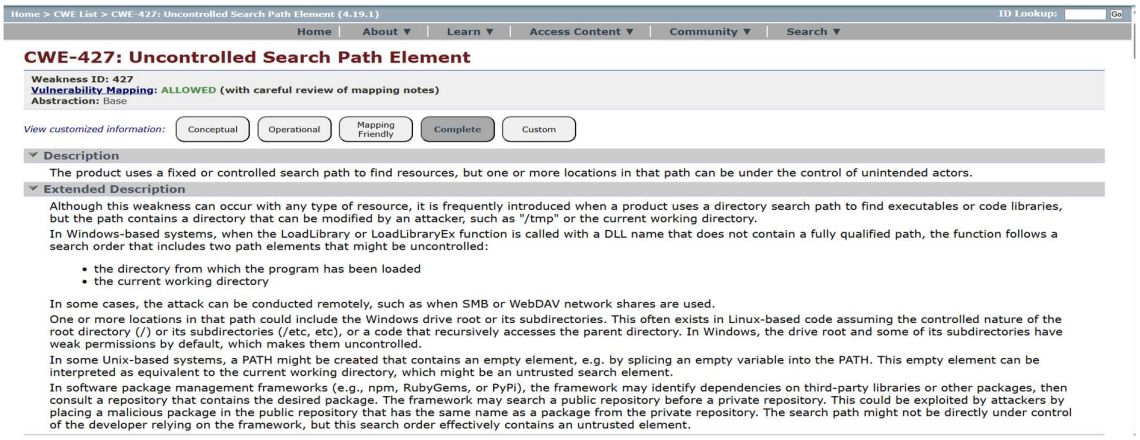
Owasp category : A08:2025 Software or Data Integrity Failures

Description :

Uncontrolled Search Path Element is a vulnerability that occurs when an application searches for executable files or libraries in directories that can be modified by attackers. This allows attackers to place malicious files in those locations so the system may execute them instead of the legitimate program

Bussiness impact :

This vulnerability can lead to execution of malicious code, system compromise, and unauthorized access to sensitive data. It may result in financial loss, operational disruption, data breaches, and damage to the organization's reputation



Home > CWE List > CWE-427: Uncontrolled Search Path Element (4.19.1)

ID Lookup: Go

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

CWE-427: Uncontrolled Search Path Element

Weakness ID: 427
Vulnerability Mapping: ALLOWED (with careful review of mapping notes)
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product uses a fixed or controlled search path to find resources, but one or more locations in that path can be under the control of unintended actors.

Extended Description

Although this weakness can occur with any type of resource, it is frequently introduced when a product uses a directory search path to find executables or code libraries, but the path contains a directory that can be modified by an attacker, such as "/tmp" or the current working directory.

In Windows-based systems, when the LoadLibrary or LoadLibraryEx function is called with a DLL name that does not contain a fully qualified path, the function follows a search order that includes two path elements that might be uncontrolled:

- the directory from which the program has been loaded
- the current working directory

In some cases, the attack can be conducted remotely, such as when SMB or WebDAV network shares are used.

One or more locations in that path could include the Windows drive root or its subdirectories. This often exists in Linux-based code assuming the controlled nature of the root directory (/) or its subdirectories (/etc, etc), or a code that recursively accesses the parent directory. In Windows, the drive root and some of its subdirectories have weak permissions by default, which makes them uncontrolled.

In some Unix-based systems, a PATH might be created that contains an empty element, e.g. by splicing an empty variable into the PATH. This empty element can be interpreted as equivalent to the current working directory, which might be an untrusted search element.

In software package management frameworks (e.g., npm, RubyGems, or PyPi), the framework may identify dependencies on third-party libraries or other packages, then consult a repository that contains the desired package. The framework may search a public repository before a private repository. This could be exploited by attackers by placing a malicious package in the public repository that has the same name as a package from the private repository. The search path might not be directly under control of the developer relying on the framework, but this search order effectively contains an untrusted element.

Vulnerability Name : Improper Output Neutralization for Logs

CWE/CVE no : CWE 117

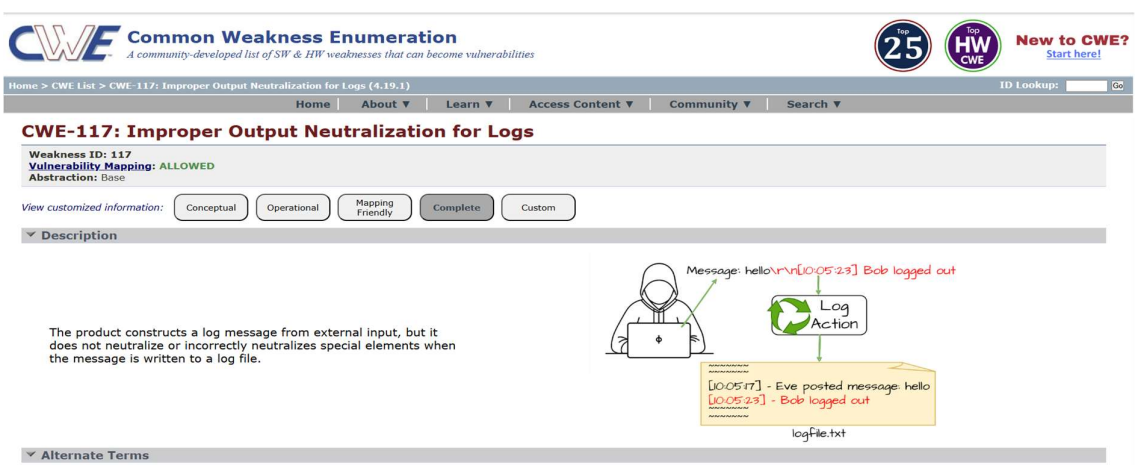
Owasp category : A09:2025 Security Logging & Alerting Failures

Description:

Improper Output Neutralization for Logs occurs when an application records user input in log files without properly sanitizing or neutralizing it. This allows attackers to inject malicious content into logs, potentially manipulating log records or hiding malicious activities.

Business Impact:

This vulnerability can lead to tampered or misleading logs, difficulty in detecting security incidents, and potential system compromise. It may also result in compliance issues, operational risks, and damage to the organization's reputation.



Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities

Top 25 | Top HW CWE | New to CWE? Start here!

Home > CWE List > CWE-117: Improper Output Neutralization for Logs (4.19.1)

ID Lookup: Go

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

CWE-117: Improper Output Neutralization for Logs

Weakness ID: 117
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product constructs a log message from external input, but it does not neutralize or incorrectly neutralizes special elements when the message is written to a log file.

Alternate Terms

Vulnerability Name : Uncaught Exception

CWE/CVE no : CWE 248

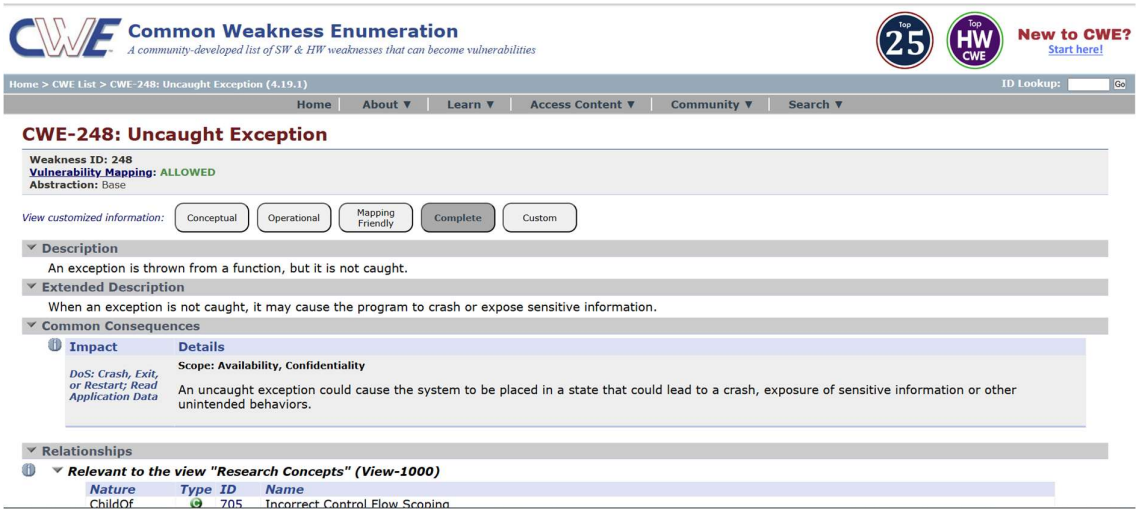
Owasp category : A10:2025 Mishandling of Exceptional Conditions

Description:

Uncaught Exception occurs when an application fails to properly handle unexpected errors during execution. This can cause the application to crash or expose sensitive system information such as stack traces, file paths, or configuration details.

Business Impact:

This vulnerability can lead to **application downtime, information disclosure, and poor user experience**. It may also result in **operational disruption, security risks, and damage to the organization's reputation**.



Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities

Top 25 | Top HW CWE | New to CWE? Start here!

Home > CWE List > CWE-248: Uncaught Exception (4.19.1) | ID Lookup: Go

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

CWE-248: Uncaught Exception

Weakness ID: 248
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

An exception is thrown from a function, but it is not caught.

Extended Description

When an exception is not caught, it may cause the program to crash or expose sensitive information.

Common Consequences

Impact	Details
DoS: Crash, Exit, or Restart; Read Application Data	**Scope: Availability, Confidentiality** An uncaught exception could cause the system to be placed in a state that could lead to a crash, exposure of sensitive information or other unintended behaviors.

Relationships

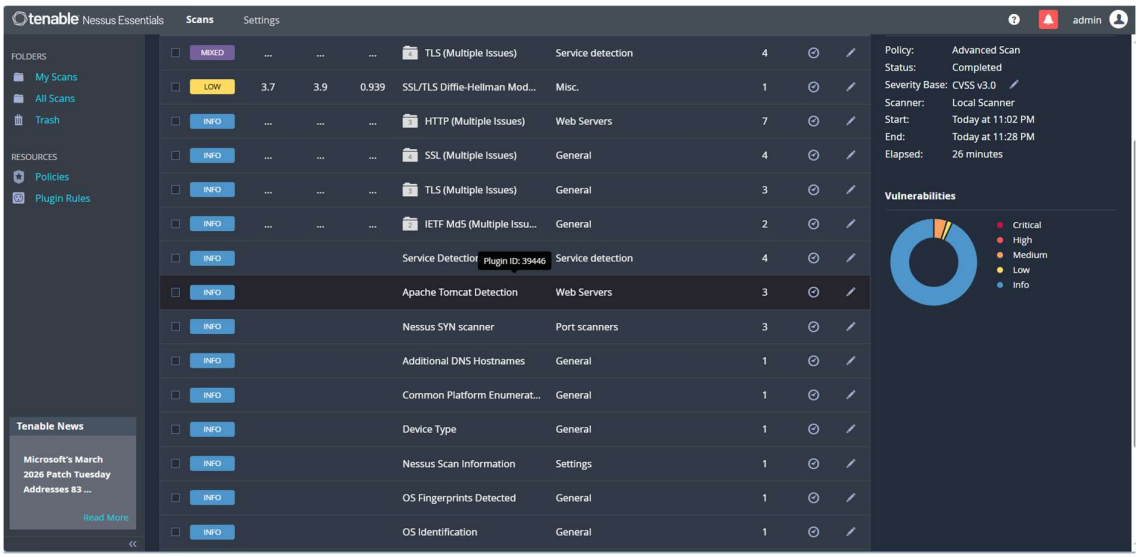
Relevant to the view "Research Concepts" (View-1000)

Nature	Type	ID	Name
ChildOf		705	Incorrect Control Flow Scoping

Stage 2

Title : nessus scan

Nessus Scan Report :



Overview:

Nessus is one of the most widely used vulnerability assessment tools designed to help organizations identify and manage security weaknesses across their IT infrastructure. A Nessus scan systematically examines systems, applications, and networks to detect misconfigurations, missing patches, insecure settings, and known vulnerabilities that attackers could exploit.

The tool works by running a series of checks against target systems, comparing them with a constantly updated database of vulnerabilities. It can identify issues such as outdated software, weak passwords, open ports, and compliance gaps. Nessus provides detailed reports that classify vulnerabilities by severity, helping security teams prioritize remediation efforts based on risk.

From a business perspective, Nessus scans are essential for maintaining regulatory compliance, reducing the likelihood of breaches, and strengthening overall security posture. By proactively identifying vulnerabilities, organizations can address them before they are exploited, thereby minimizing financial losses, reputational damage, and operational disruptions.

In summary, a Nessus scan offers organizations a comprehensive, automated, and reliable method to assess their security environment. It enables proactive risk management, supports compliance requirements, and provides actionable insights that help businesses safeguard critical assets in today's evolving threat landscape.

S.no	Vulnerability Name	Severity	plugin
1	Service Detection	info	22964
2	Apache Tomcat Detection	Info	39446
3	HTTP Server Type and Version	Info	10107
4	HyperText Transfer Protocol (HTTP) Information	info	24260
5	Nessus SYN scanner	info	11219
6	TCP/IP Timestamps Supported	info	25220
7	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)	low	83875
8	TLS Version 1.0 Protocol Detection	medium	104743
9	TLS Version 1.1 Deprecated Protocol	medium	157288
10	Traceroute Information	info	10287

Target Website : testfire.net

Target IP Address : 65.61.137.117

Report:

1.Vulnerability Name : Service Detection

Severity: info

Plugin: 22964

Port: N/A

Description: Service Detection refers to the ability of attackers or scanning tools to identify running services, open ports, and software versions on a system or network. This information can help attackers understand the system environment and find potential vulnerabilities to exploit.

Solution: Organizations should disable unnecessary services, close unused ports, implement firewalls, and regularly update software. Additionally, using network monitoring and intrusion detection systems (IDS) can help detect and prevent unauthorized service discovery.

Bussiness impact : If attackers successfully detect services, they may identify vulnerable systems and launch targeted attacks, leading to data breaches, system compromise, service disruption, financial loss, and reputational damage.

2.Vulnerability Name : Apache Tomcat Detection

Severity: info

Plugin: 39446

Port: N/A

Description:
Apache Tomcat Detection occurs when attackers or scanning tools identify that a server is running the Apache Tomcat web server along with its version information. If the detected version has known vulnerabilities, attackers may attempt to exploit them to gain unauthorized access or disrupt services.

Solution:
Organizations should hide server version details, keep Apache Tomcat updated to the latest secure version, restrict access to management interfaces, and implement firewalls and security monitoring tools to reduce exposure.

Business Impact:
If attackers detect vulnerable Tomcat servers, they may exploit security flaws to access sensitive data, execute malicious code, or disrupt web services, resulting in data breaches, operational downtime, financial loss, and reputational damage.

3.Vulnerability Name : HTTP Server Type and Version

Severity: info

Plugin: 10107

Port: N/A

Description:
HTTP Server Type and Version Disclosure occurs when a web server reveals its software type and version information in HTTP response headers. Attackers can use this information to identify known vulnerabilities in the specific server version and plan targeted attacks.

Solution:
Organizations should hide or remove server version details from HTTP headers, keep server software updated, implement web application firewalls (WAF), and follow secure server configuration practices to reduce information exposure.

Business Impact:
This vulnerability can help attackers identify exploitable weaknesses, potentially leading to unauthorized access, system compromise, service disruption, financial loss, and damage to the organization's reputation**.**

4.Vulnerability Name : HyperText Transfer Protocol (HTTP) Information

Severity: info

Plugin: 24260

Port: N/A

Description:
HyperText Transfer Protocol (HTTP) Information Disclosure occurs when a web server exposes unnecessary details through HTTP responses, headers, or error messages. Attackers can use this information to understand the system environment and identify potential vulnerabilities.

Solution:
Organizations should limit information exposed in HTTP responses, disable detailed error messages, configure secure HTTP headers, and keep server software updated to reduce the risk of information leakage.

Business Impact:
This vulnerability can help attackers gather system details to plan targeted attacks, which may lead to security breaches, system compromise, service disruption, financial loss, and reputational damage.

5.Vulnerability Name : Nessus SYN scanner

Severity: info

Plugin: 11219

Port: N/A

Description:
Nessus SYN Scanner is a scanning technique used by the Nessus tool to identify open ports and running services on a target system by sending SYN packets. It helps detect network exposure and potential vulnerabilities that attackers could exploit.

Solution:
Organizations should implement firewalls, restrict unnecessary open ports, use intrusion detection/prevention systems (IDS/IPS), and monitor network traffic to detect and block unauthorized scanning activities.

Business Impact:
If attackers perform SYN scans, they can discover open ports and vulnerable services, which may lead to targeted attacks, unauthorized access, service disruption, financial loss, and reputational damage.

6.Vulnerability Name : TCP/IP Timestamps Supported

Severity: info

Plugin: 25220

Port: N/A

Description:
TCP/IP Timestamps Supported is a vulnerability where a system includes timestamp values in TCP packets. Attackers can analyze these timestamps to estimate system uptime and gather information about the operating system, which may assist in reconnaissance activities.

Solution:
Organizations should disable TCP timestamps if not required, apply secure network configurations, and use firewalls or intrusion detection systems to monitor suspicious network activities. Keeping systems updated also helps reduce related risks.

Business Impact:
This vulnerability may allow attackers to collect system information and plan targeted attacks, potentially leading to security breaches, system compromise, operational disruption, and reputational damage**.**

7.Vulnerability Name : SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)

Severity: low

Plugin: 83875

Port: N/A

Description:
SSL/TLS Diffie-Hellman Modulus ≤ 1024 Bits (Logjam) is a vulnerability where servers use weak Diffie-Hellman key exchange parameters with a modulus size of 1024 bits or less during SSL/TLS communication. Attackers can exploit this weakness through the Logjam attack to downgrade secure connections and potentially decrypt encrypted traffic.

Solution:
Organizations should disable weak Diffie-Hellman parameters, use stronger keys (2048 bits or higher), update SSL/TLS configurations, and enable modern secure cipher suites. Regular security updates and vulnerability scans are also recommended.

Business Impact:
This vulnerability can allow attackers to intercept and decrypt sensitive communications, leading to data breaches, exposure of confidential information, financial losses, compliance violations, and reputational damage.

8.Vulnerability Name : TLS Version 1.0 Protocol Detection

Severity: medium

Plugin: 104743

Port: N/A

Description:
TLS Version 1.0 Protocol Detection occurs when a server supports the outdated Transport Layer Security protocol for secure communications. Since TLS 1.0 contains known security weaknesses, attackers may exploit these vulnerabilities to compromise encrypted connections.

Solution:
Organizations should disable TLS 1.0 on servers and enable newer, secure protocols such as Transport Layer Security or Transport Layer Security. Regularly updating server configurations and following modern security standards will help maintain strong encryption.

Business Impact:
Using outdated encryption protocols can expose sensitive data to interception and attacks, potentially causing data breaches, compliance violations, financial loss, and damage to the organization's reputation.

9.Vulnerability Name : TLS Version 1.1 Deprecated Protocol

Severity: medium

Plugin: 157288

Port: N/A

Description:
TLS Version 1.1 Deprecated Protocol occurs when a server still supports the outdated Transport Layer Security protocol for encrypted communication. Since TLS 1.1 is deprecated and contains known security weaknesses, it may expose systems to potential attacks.

Solution:
Organizations should disable TLS 1.1 and enable more secure protocols such as Transport Layer Security or Transport Layer Security. Keeping servers updated and following modern security standards will strengthen encryption.

Business Impact:
Supporting deprecated protocols can lead to interception of sensitive data, security breaches, and non-compliance with industry standards, potentially causing financial loss and reputational damage.

10.Vulnerability Name : Traceroute Information

Severity: info

Plugin: 10287

Port: N/A

Description:
Traceroute Information Disclosure occurs when network devices respond to traceroute requests, revealing details about the network path, including intermediate routers and IP addresses. Attackers can use this information to map the network structure and identify potential targets.

Solution:
Organizations should configure firewalls and routers to restrict or block traceroute responses, disable unnecessary ICMP responses, and implement network monitoring tools to limit exposure of internal network details.

Business Impact:
This vulnerability can help attackers gather network topology information, which may lead to targeted attacks, unauthorized access, service disruption, and potential financial and reputational damage.

Stage 3

Title : Design And apply context-aware access controls based on user identity, device posture, location, and application risk.

Overview:

Context-aware access control is a security approach that grants or restricts access to systems and data based on multiple factors such as **user identity, device security status (device posture), location, and application risk level**. By evaluating these contextual elements in real time, organizations can ensure that only authorized users with trusted devices and appropriate conditions are allowed to access sensitive resources, thereby strengthening overall security and reducing the risk of unauthorized access.

Identity :

Identity refers to the unique digital identification of a user within a system, such as a username, email, or employee ID, used to verify who is requesting access to resources. It helps organizations **authenticate users, manage permissions, and ensure that only authorized individuals can access sensitive systems or data**.

Device posture :

Device posture refers to the **security status and health of a device** attempting to access a system or network. It evaluates factors such as **operating system updates, antivirus status, security patches, and device compliance** to ensure that only secure and trusted devices are allowed to access organizational resources.

Application Risk :

Application risk refers to the **potential security threats associated with using a particular application**, based on factors such as the sensitivity of data it handles, its security vulnerabilities, and its access permissions. Evaluating application risk helps organizations **control access and protect sensitive information from unauthorized or risky applications**.

Context aware access :

Context-aware access is a security approach that controls user access to systems and data by analyzing contextual factors such as **user identity, device posture, location, time, and application risk**. This ensures that **access is granted only when the request meets defined security conditions**, improving protection against unauthorized access.

Conclusion :

Stage 1

The design and implementation of context-aware access controls play a vital role in strengthening modern cybersecurity frameworks. As organizations increasingly rely on digital platforms, cloud services, and remote access, traditional security models are no longer adequate to protect sensitive data and critical systems. By incorporating contextual factors such as user identity, device posture, location, and application risk, organizations can make more intelligent and adaptive access decisions that reflect the real-time risk associated with each request. This dynamic approach ensures that legitimate users are granted appropriate access while suspicious or high-risk attempts are restricted or subjected to additional verification.

The identification of various vulnerabilities—such as Absolute Path Traversal, Sensitive Cookies without Secure attributes, Use of Unmaintained Third-Party Components, Hard-coded Cryptographic Keys, Code Injection, Improper Privilege Management, Improper Certificate Validation, Uncontrolled Search Path Elements, Improper Log Neutralization, and Uncaught Exceptions—highlights the importance of implementing strong security practices across applications and infrastructure. Each of these vulnerabilities can potentially expose systems to unauthorized access, data leakage, or operational disruptions if not properly addressed.

By integrating context-aware access controls with secure coding practices, vulnerability management, and regular security assessments, organizations can significantly reduce the attack surface of their systems. This approach aligns with the Zero Trust security model, where every access request is continuously verified rather than automatically trusted. Ultimately, adopting context-aware security mechanisms not only improves protection against cyber threats but also enhances operational resilience, regulatory compliance, and user trust in the organization's digital environment.

Stage 2

The Nessus vulnerability scan provides valuable insights into the security posture of the system by identifying potential weaknesses and configuration issues. The scan results indicate several detected items, including informational, low, and medium-severity vulnerabilities related to network services, server configurations, and encryption protocols. Informational findings such as Service Detection, Apache Tomcat Detection, HTTP Server Type and Version Disclosure, HTTP Information Exposure, Nessus SYN Scanner, TCP/IP Timestamp Support, and Traceroute Information mainly reveal system details that attackers could use for reconnaissance and planning targeted attacks.

In addition to these informational findings, the scan also identified more significant issues such as SSL/TLS Diffie-Hellman Modulus ≤ 1024 Bits (Logjam) and the presence of outdated encryption protocols like TLS 1.0 and TLS 1.1. These vulnerabilities indicate weaknesses in the system's cryptographic configuration, which could potentially allow

attackers to intercept or weaken encrypted communications. Addressing these issues by disabling deprecated protocols and implementing stronger encryption standards will significantly improve the system's security.

Overall, the results of the Nessus scan highlight the importance of continuous vulnerability assessment, secure configuration practices, and timely updates. By reviewing and remediating the identified issues, organizations can reduce potential attack surfaces, enhance system resilience, and ensure a stronger and more secure network environment.

Stage 3

In today's evolving digital environment, implementing context-aware access controls is essential for protecting organizational systems and sensitive data. By considering multiple contextual factors such as user identity, device posture, location, and application risk, organizations can make more accurate and secure access decisions. This approach ensures that only verified users with secure devices and appropriate conditions are granted access to critical resources.

Unlike traditional access control methods that rely solely on static credentials, context-aware access introduces a dynamic and risk-based security model. It continuously evaluates the security posture of the access request, allowing organizations to apply stricter controls when risks are higher and provide seamless access when conditions are trusted. This helps reduce the chances of unauthorized access, insider threats, and data breaches.

Furthermore, adopting context-aware access supports modern security strategies such as Zero Trust, where trust is never assumed and every access request is verified. By integrating identity verification, device security checks, and application risk analysis, organizations can strengthen their overall security framework while maintaining a smooth and efficient user experience. Ultimately, context-aware access control plays a critical role in building a secure, adaptive, and resilient digital infrastructure.

Future scope :

Stage 1

The implementation of context-aware access controls provides a strong foundation for improving organizational security, but there are several opportunities for further development and enhancement in the future. As cyber threats continue to evolve, organizations can integrate advanced technologies such as artificial intelligence (AI) and machine learning (ML) to analyze user behavior patterns and automatically detect unusual access attempts. These intelligent systems can continuously learn from user activities and dynamically adjust access policies to improve threat detection and prevention.

Another important future direction is the deeper integration of Zero Trust architecture, where every user, device, and application must be continuously verified before gaining access to organizational resources. Combining context-aware access with Zero Trust models will

further strengthen security by ensuring that trust is never assumed and that access decisions are always based on real-time risk evaluation.

Organizations can also expand the scope of context-aware access by incorporating additional contextual factors, such as behavioral analytics, time-based access policies, and network conditions. This will enable more precise access control decisions and reduce the likelihood of unauthorized access or insider threats. Furthermore, the use of cloud-based identity and access management (IAM) solutions can help organizations manage context-aware policies across hybrid and multi-cloud environments.

In the future, improved automation

Stage 2

In the future, organizations can further strengthen their security posture by implementing regular automated vulnerability scanning and continuous monitoring using advanced security tools. Integrating vulnerability management with security information and event management (SIEM) systems can help detect threats in real time and respond more quickly to potential security incidents.

Additionally, organizations should focus on upgrading cryptographic protocols and enforcing strong encryption standards, such as using newer TLS versions and stronger key exchange mechanisms. Expanding the use of security best practices, patch management, and regular penetration testing will also help identify and mitigate new vulnerabilities as technology evolves.

Furthermore, combining vulnerability scanning tools like Nessus with automated security frameworks, cloud security monitoring, and zero-trust architecture can significantly improve overall defense mechanisms. By continuously improving security strategies and adopting modern technologies, organizations can build a more resilient infrastructure capable of protecting systems and sensitive data from emerging cyber threats.

Stage 3

The future of context-aware access control lies in the integration of advanced technologies and intelligent security frameworks. As cyber threats continue to grow in complexity, organizations can enhance context-aware systems by incorporating artificial intelligence (AI) and machine learning (ML) to analyze user behavior patterns and automatically detect unusual or suspicious access attempts. These technologies can help organizations make faster and more accurate security decisions by continuously learning from user activities and system interactions.

Another important future direction is the stronger adoption of Zero Trust architecture, where every access request is continuously verified regardless of the user’s location or network. By combining context-aware access with Zero Trust principles, organizations can create more secure environments where trust is never assumed and access is granted only after thorough verification.

In addition, organizations can expand context-aware access controls by including additional contextual factors, such as behavioral analytics, time-based access policies, network risk levels, and real-time threat intelligence. The integration of cloud-based identity and access management (IAM) solutions will also allow organizations to apply context-aware policies consistently across hybrid and multi-cloud environments.

Furthermore, future developments may involve automated security orchestration and response systems, which can automatically respond to suspicious activities by restricting access, triggering alerts, or enforcing stronger authentication measures. By continuing to evolve and integrate these advanced security technologies, organizations will be able to build more adaptive, resilient, and intelligent security systems that effectively protect critical data and resources.

Topics Explored:

1.owasp top 10

2. Scanning

3. Vulnerability

4.Awareness

5.identity

Tools Explored:

1. Zscaler

2.Nessus

3.Owasp

4.hackthissite